



More Is Not the Answer

Cormac Herley | Microsoft Research

Progress in user security has been slow for several reasons. First, the Web's scale and diversity make one-size-fits-all approaches hard. Second, the competition for user attention is fierce: there are no pools of unexploited user effort to be had. Third, persuasion is the only tool we have, mandates being often impossible or undesirable. We need to find new techniques to improve user security.

U sable security has progressed a great deal in the past 10 years. Initially, simply establishing the importance of the human factor in security was an uphill battle. That the interface of a crypto product, rather than its users, might be to blame for its lack of adoption was not the accepted wisdom in 1999.¹ That security might need to learn about users, as well as the other way around, was far from the popular view.² Things have changed. The need to factor users' capabilities and understanding into the design of security technologies is no longer controversial.

Users are the notoriously weakest link in many security chains; the easiest way to gain access to many resources is simply to convince, trick, or spoof someone into granting it. The attack that compromised RSA's master keys began with an employee clicking a malicious link. Stuxnet bridged the air gap between isolated machines by correctly assuming that people would ferry files between them using USB thumb drives.

A major disappointment, then, for many security professionals is the continuing lack of engagement on the part of the computer-using population. That consequences can be serious, and that much of the risk is related to user behavior seems not in doubt. Yet, the

online population seems largely impervious to efforts to get them to take security more seriously.

An approach to explaining this fact is offered by Adam Beaument and his colleagues who suggest that users have a limited tolerance, or budget, for compliance with security requests.³ Beyond a certain threshold, increasing demands are simply met with attempts to circumvent onerous procedures. The thresholds appear to have been long exceeded for most users. Previous work suggested that, from a cost-benefit standpoint, users are rational to reject much security advice: the burden imposed is simply too great for the benefit received. We might view the lack of care that users show for security as disappointing.⁴ A more extreme view might consider it dangerous or even a threat to national security. However, it is certainly no puzzle: if users reject the bargain they are offered, it is simply because we have failed to make a convincing case.

If we are unhappy with this state of affairs (and it appears that many are), then change is needed. The emphasis on studying user behavior is a welcome improvement. However, it is tempting to believe that human factors can be used as a toolbox of techniques to increase the time and effort users spend on security.

Better design of security indicators and warnings might increase the notice people take of them, and better password strength meters might nudge them in the direction of greater strength. Although these are interesting approaches, this still ignores the fundamental problem: spending more time on security is not an inherent good. Before asking for more of anything, we should demonstrate that we're making good use of what we have. Not only are we unable to demonstrate this, but it has become increasingly obvious that we have used our resources wastefully. We spend too much time asking for more and not enough optimizing use of what we have.

In this article, we explore reasons why progress has been slow and examine several possible directions. First, the scale and diversity of the Web make one-size-fits-all approaches hard. Second, the competition for user attention is fierce: there are no pools of unexploited user effort to be had. Third, persuasion is the only tool we have, mandates being often impossible or undesirable. Charting a way forward in these circumstances is hard. However, we outline several steps to improve the field.

Scale and Diversity of the Modern Web

In 2013, there were upwards of 2 billion Internet users, whereas in 1990, the total number of people with access to networked computers was about 2 million. Not only are more people using computers, but they are using computers more. The networked machines of 1990 were expensive devices, housed in controlled-access environments, and used generally for high-value tasks. Today, by contrast, hundreds of millions carry smartphones, laptops, and tablets. Instead of a single computer account, many in the developed world will have on the order of 100 password-protected accounts, covering everything from banking to email, online video streaming to social networking. Facebook reported having 1.15 billion active users in March 2013, and numerous services have hundreds of millions.

Scale raises the cost of any changes we might propose. Consider the case of passwords. If we assume that each of 2 billion users spends 5 seconds per day typing passwords, it amounts to 1,389 man years per day of human effort. Any technology that seeks to replace passwords with a technique requiring more than 5 seconds imposes an enormous aggregate burden. An hour from each of the US's 180 million online users is worth approximately US\$2.5 billion.⁴ A major error in security thinking has been to treat users' time—an extremely valuable resource—as free. Thus, the importance of getting things right and not wasting user effort cannot be overstated.

As impressive as the Web's scale is its diversity. Not only is there enormous diversity of Web services, there is enormous diversity in how those services are used.

The same service might be of great consequence to one user and almost unimportant to another; for instance, an investment site might have accounts with million-dollar portfolios and ones with a few hundred, and a social networking site might be all-important to one user and all-but-unused by another. The same is true of hardware: some computers are used simply for surfing the Web, whereas others are used to handle major financial transactions or control critical infrastructure. Thus, essentially the same security technologies end up having to protect assets that vary in value by orders of magnitude. The same browser and the same OS (and the same sets of security warnings and cues) handle a great range of assets. The same commodity hardware and operating systems that control nuclear centrifuges are used for email and surfing the Web. It is difficult to design mechanisms that are equally appropriate for assets that differ in value so dramatically. Something that is up to the task of protecting high-value assets and critical infrastructure will be wasteful and unnecessary for low-value assets. The level of user care that we can expect varies by orders of magnitude. It is extremely difficult to design advice and usable security mechanisms that are divorced of context.

Competition for User Attention Is Fierce

The answer to many usable security questions seems to be “more.” We demand more password strength from users and ask them to change them more often. They should pay more attention to errors and warnings, and stop and think more before they click. They should educate themselves about their browsers' and OSs' safety and security indicators and take more notice when anything strange happens. They should spend more time considering the potential consequences of their actions.

When pondering the difficulty of making this happen, it is worth remembering that competition for user attention is fierce. Millions of websites, blogs, and feeds compete for notice. A majority of the most popular sites are advertising-supported, and there is a direct relation between traffic and dollars. Search results are surrounded by sponsored links. News stories with “clickbait” headlines are covered in banners and preceded and followed by offers to take surveys. Articles are broken into several pages to multiply the number of advertising impressions served. Advertising popups drift across the screen at a speed calculated to make clicking the Close button especially difficult.

The battle for user attention is not limited to advertising. Installing a new application is a process often peppered with interruptions about installing unrelated applications, receiving updates, placing icons on the desktop, and changing the default search engine. New machines often come laden with free trials of software,

such as antivirus packages, that noisily announce their presence and make increasingly insistent pleas as the end of the trial period approaches.

The reason for this theater of distractions is simple: user traffic, attention, and eyeballs are the coin of the realm. Most successful Web companies make money by monetizing their access to users. This complicates the question of security for two reasons. First, security indicators appear, and security decisions must be made, with a carnival of distractions running in the background. Even if security indicators were clear, consistent, and unambiguous (and they most certainly are not), they are hard to notice against the constant attempts to lure user attention elsewhere. Second, when asking for user time and attention we are asking for the single thing that is in most demand on the Internet. Facebook was valued at \$100 billion based on the expectation that it could translate its enormous share of user attention and interaction into earnings.

Thus, security must make its way in an extremely competitive environment. Not only are there no unclaimed pools of user effort to be had, it is difficult to preserve existing pools from incursions. It is hard to reserve time, effort, screen real estate, and techniques for security when each of them is a valuable and monetizable resource.

Persuasion Rather Than Mandates

It is an ongoing frustration for many security professionals that users show so much reluctance on security matters. A natural question, then, is why so many things are optional rather than mandated? If the correct course of action is clear and straightforward, why are incorrect ones even options? If weak passwords are such a threat, why do so many sites allow them? If the right action on receiving a warning is obvious, why is any other course even offered?

The answer, of course, is that the correct course of action is seldom as clear as we might like. Many things can't be mandated for the simple reason that what we are asking the user to do is not clearly defined, and by substituting something that is clearly defined, we do not accomplish the original goal. Onerous password policies can be mandated but do not guarantee good resistance to guessing attacks.⁵ We can enforce password expiration, but again, this does little to enhance strength.⁶ While we can ask users to pay attention to security warnings, we can't anticipate whether any particular warning will be a true or false positive. We resort to asking users to avoid "suspicious links," because we have nothing approaching a clearer definition. Thus, things are often not clear, and we must rely on users' judgment. That being the case, we must persuade them that it is worth their while.

The battle for user attention is fierce. Thus, the burden of proof for those who ask for more of it is large: that the benefit is greater than the cost must be shown, not assumed or asserted. In the consumer space, users bear the cost of increased security measures and users receive the benefit. Users also make the decisions about where to make an effort and where to take shortcuts. Clearly, the perceived benefit to users is less than the perceived cost. Although it is possible that they are wrong (that is, the actual benefit to users is greater than the actual cost, even though they don't perceive it that way), this hardly matters: if users cannot be forced into measures, then their judgment of the benefit and cost is the final court of appeal in the matter. Complaints that users don't understand, are misinformed, and so on, are simply distractions from the fact that the evidence as presented doesn't convince those who decide.

While we frequently resort to worst-case analysis and scenarios, we seldom provide clear evidence that security measures reduce harm to a degree that merits the effort. Since competition for access to users is fierce and mandates work only in limited settings, like everything else, security must make the case for the resources it wants to consume.

Protecting Users Less Badly

While usable security has had many successes in pointing out security UI failings, progress has been slower in providing actionable alternatives. It is difficult to give prescriptive answers on how things might be done better. Password advice is bad,⁷ but how might we do better? Security indicators are ignored,⁸ but what should we use in their place? Suspicious links might be hard to define,⁴ but we cannot just ignore the problem. Although searching clear steps to do well is difficult, a more modest goal is to do less badly. We next explore a number of approaches.

Never Give an Order You Know Will Be Disobeyed

As we've seen earlier, the answer to many security questions can seem to be to ask more of users. Even if we find their reluctance disappointing, we can no longer consider it a surprise. (In fact, it is argued above and elsewhere that users are right to reject a bargain that offers a poor cost-benefit trade-off.^{4,7}) We have known for some time that users persistently seek shortcuts, and complying with security requirements appears to be low on their list of priorities. This isn't surprising because security is seldom the main task, the benefit received is seldom salient (and is almost never shown to be greater than the cost), and there are many competing (and more compelling) demands on users' time.

It seems safe to assume that this will continue:

overwhelmed users will do the minimum of what is mandated and ignore what is optional. Since we know this, plausible deniability is gone. We can no longer feign surprise when passwords are widely reused and popup warnings ignored. It follows that observed user behavior must be considered a constraint, and realistic security designs must not assume more. Security regimes that assume higher levels seem destined for predictable failure.

Yet, security experts, service providers, and government agencies frequently offer users advice that we know has no possibility of being followed. Some of it is just unworkable; it imposes a burden that no reasonable user can pay. Some of it is just too vague and does little beyond confuse the issue. A lot of advice has poor cost-benefit trade-off and is overkill for the assets at stake. Finally, there is just too much of it, and the cumulative effect is overwhelming. Without guidance on what to respect and what to ignore, users are left to their own devices.

This all has an effect on credibility. If we insist on the necessity of measures that are ignored wholesale, we simply draw attention to the gap between what we consider necessary and what users find they can get away with. It suggests that our goal in giving advice is something other than reducing harm.

When You Don't Know, Say You Don't Know

Confessing ignorance can seem incompatible with being considered an expert. Yet, security claims often appear little better (and, in some cases, much worse) than guesswork. Honesty demands that we be more frank about the limits of our knowledge.

On the issue of password strength, much mischief has been caused by our unwillingness to admit that we don't have a clear understanding of how to measure strength, how to achieve it, or how much of it is needed. This has led to our insistence on the importance of measures that turn out to be almost unrelated to guessing resistance.⁵ It has led to password meters that classify "Pa\$\$w0rd" as very strong and "wpnfusg" as weak. It has led to the knock-on effect of countless organizations mandating complex password policies that appear unrelated to security^{2,9} and periodic password changes that appear to accomplish little.⁶ As argued earlier, the scale of deployment is such that inefficiencies are a luxury we cannot afford. Our share of user time and effort is too valuable to waste; measures without compelling evidence of efficacy should be reconsidered or dropped.

As outlined earlier, a great deal of what we ask of

users can't be mandated (or implemented in the OS or browser) because it is vague. Again, the Web is a diverse place. Any rule about how URLs should look will almost certainly have many benign exceptions. In longtail phenomena, treating anomalies as "suspicious" is asking to be flooded with false positives. If we cannot describe clearly the types of links users should avoid, it is better

to be silent than offer frustrating and ambiguous instructions.

The frequency with which harm happens is important and a matter on which we are largely ignorant. Bad things

certainly happen; people have passwords snooped, machines compromised, and money stolen. Negligence on security matters can and does lead to real grief. However, a weak password does not always lead to theft, and clicking through a warning does not always lead to compromise. A major point of disconnect between security practitioners and users appears to be the difference between worst-case and average outcomes.⁴ If we lack firm evidence of average cases, honesty demands that we admit it rather than invoke worst-case harms.

Finally, estimates of cybercrime losses are often invoked in an effort to sell security measures. Reports that cybercrime is bigger than the global drug trade and that identity theft is rapidly growing can seem like convenient props to help make the case. Great caution is needed here. First, this tactic isn't effective: if exaggerated claims were useful in influencing users toward more security, it would have worked by now. Second, estimates of cybercrime losses are notoriously bad, and many turn out to be generated using unsound statistical methods.¹⁰ Resorting to tainted evidence to sell the importance of what we do suggests an inability to convince by honest means.

Don't Deny the Obvious

In security, it is convenient to abstract all context away and consider only technical measures. This lets us ignore questions of gain, cost, loss, and motivation. Although convenient and a very natural technical approach, this technique fails to differentiate between high- and low-value targets. The passwords that protect a substantial bank account and a throwaway email account need not be treated with the same care. Sometimes, low-assurance resources can be leveraged into high-assurance ones. However, to claim that this generally happens is to deny the obvious and ignore a major inconsistency: if worst-case outcomes are typical, why isn't everyone hacked every day? Most security advice errs on the

It is hard to persuade users that what we ask them to do is not arbitrary and capricious when much of it is, in fact, arbitrary and capricious.

side of caution and is appropriate for high-value assets, where unbounded attacker effort is expected. However, most users have many low-value assets where attacker effort that is greater than the expected value is unlikely. Thus, we have a large void. We have some (albeit imperfect) understanding of the measures necessary to protect high-value assets, but we lack good tools to decide which of those measures can be neglected when protecting low-value ones. The burgeoning field of security economics holds some promise in this area,¹¹ but much more work is needed. However, pretending that low-assurance problems must be treated with the same care as high-assurance ones is counterproductive and puts us in the awkward position of insisting on the truth of something that billions can see is false.

We cautioned against using worst-case scenarios when average-case scenarios are what users care about. A related error is exaggerating the frequency of harm or average losses. Generally, things are not as bad as we say. The Internet has 2 billion users who mostly derive more good from it than harm. Bad things certainly happen. A large collection of would-be criminals seek to prey on the online population. However, turning code and stolen passwords into money is a lot harder than it looks.¹² Espousing a view of the world in which ordinary consumers regularly lose money to cybercrime requires an almost willful ability to ignore inconsistencies.

Be Prepared to Admit Mistakes

Considering the battle over users' time and the scale of the Web, user time and attention should be used only as a last resort. We should ask for it only after exhausting all other possibilities. Unfortunately, evidence suggests that we have used user effort as a first resort, not last.

For example, passwords have long suffered from the problem of offline guessing attacks. This has given rise to a variety of policies (that constrain passwords' composition and length), expiration rules (that force them to be changed regularly), and tips and advice (that govern their choice and maintenance). These policies are all tools to address the end problem of offline attacks on passwords (although, as noted, their efficacy seems much lower than generally assumed). Of course, many engineering problems have more than one solution. Trying to alter user behavior is certainly one way to address offline guessing attacks; however, it is by no means the only way. Elegant back-end solutions exist that make offline attacks no worse than online ones.¹³ Viewed in this way, addressing offline guessing by asking effort of users is an $O(N)$ solution to the problem (where N is the number of users); the solution Giovanni Di Crescenzo and his colleagues proposed is independent of N . At worst, if large sites might need more care than small, we might consider it $O(\log N)$. In earlier times, when

the number of users was orders of magnitude smaller, some inefficiency might have been tolerable; however, consuming $O(N)$ resources on problems for which efficient solutions exist is no longer tolerable.

Indeed, the whole question of addressing offline attacks with user effort seems misguided. Encouraging users to choose passwords that will withstand online attacks seems relatively easy, and a good use of effort. Trying to get them to devote the additional effort of withstanding offline attacks is extremely hard and largely futile. The difference between the strength of password needed and the user effort required for these two cases is enormous. There should be no need to withstand an offline attack if the service does an adequate job of protecting the file of hashed passwords.^{9,13} This is an example of creating good alignment between an organizational and user goal;¹⁴ failure to do so can result in increased noncompliance.¹⁵

On this and many other questions, we appear to have lost sight of the original goal. We are pursuing substitute goals, such as password complexity and expiration, as ends in themselves long after it has become clear that they do little for the original problem. We persist on a course that was set decades ago, even though the threat landscape has changed beyond recognition and lower-cost alternatives are available.

Passwords offers egregious examples, but the picture is little better elsewhere. Users are advised to decline certificate warning options independent of any evidence of the relative frequency and costs of true and false positives. It is hard to persuade users that what we ask them to do is not arbitrary and capricious when much of it is, in fact, arbitrary and capricious. It is difficult to see a way to restore credibility that does not involve owning up to past mistakes. The fact that we have been so sure, and so wrong, so often suggests that we might profit from asking ourselves "What else have we gotten wrong?"

Usable security has many challenges. The techniques and mandates that made sense in a high-assurance world have proved hard to adapt to the vast low-assurance needs of the 2 billion Internet users. By now, most security practitioners acknowledge that forcing users to adapt to the technology is not realistic. At the other extreme, the hope that "it should just work" is, unfortunately, probably too optimistic. Thus, users will probably need to be engaged in security matters for the foreseeable future.

More is not the answer. It is easy to fall into the trap of thinking that if we find the right words or slogan, we can convince people to spend more time on security, or that usable security offers a bag of tricks to cajole users

into increasing effort. This view is profoundly in error. It presupposes that users are wrong about the cost-benefit trade-off of security measures, when the bulk of the evidence suggests the opposite. The problem with the product we offer is not simply that it lacks attractive packaging but that it offers poor return on investment. There are many ways to reduce potential harm with more user effort, yet when the answer is always “do more,” they don’t sound like the response to any question that the user population asks. However, there is a pressing need for better protection at the same or lower levels of effort. Rather than techniques to convince users to treat low-value assets as high, we need advice and tools that are appropriate to value.

Security needs to consider “going green” as far as users are concerned, in the sense of offering only advice that is effort neutral. If awareness is to be raised, then something else, somewhere, must be lowered. Measures that demand increases in user time, effort, or attention should suggest where the corresponding decreases can be found to balance things out. We need thorough reevaluation of current practices based on their efficiency in reducing harm and to reclaim, where possible, the pools of effort that we have wasted on nonproductive tasks. ■

References

1. A. Whitten and J.D. Tygar, “Why Johnny Can’t Encrypt: A Usability Evaluation of PGP 5.0,” *Proc. 8th Conf. Usenix Security Symp.*, Usenix, vol. 8, 1999, p. 14.
2. A. Adams and M.A. Sasse, “Users Are Not the Enemy,” *Comm. ACM*, vol. 42, no. 12, 1999, pp. 40–46.
3. A. Beaument, M.A. Sasse, and M. Wonham, “The Compliance Budget: Managing Security Behaviour in Organisations,” *Proc. Workshop New Security Paradigms*, ACM, 2008, pp. 47–58.
4. C. Herley, “So Long, and No Thanks for the Externalities: The Rational Rejection of Security Advice by Users,” *Proc. Workshop New Security Paradigms*, ACM, 2009, pp. 133–144.
5. M. Weir et al., “Testing Metrics for Password Creation Policies by Attacking Large Sets of Revealed Passwords,” *Proc. 17th ACM Conf. Computer and Comm. Security*, ACM, 2010, pp. 162–175.
6. Y. Zhang, F. Monrose and M.K. Reiter, “The Security of Modern Password Expiration: An Algorithmic Framework and Empirical Analysis,” *Proc. 17th ACM Conf. Computer and Comm. Security*, ACM, 2010, pp. 176–186.
7. P. Inglesant and M.A. Sasse, “The True Cost of Unusable Password Policies: Password Use in the Wild,” *Proc. SIGCHI Conf. Human Factors in Computing Systems*, ACM, 2010, pp. 383–392.
8. S. Schechter et al., “The Emperor’s New Security Indicators: An Evaluation of Website Authentication and the

Effect of Role Playing on Usability Studies,” *Proc. IEEE Symp. Security and Privacy*, IEEE CS, 2007, pp. 51–65.

9. D. Florêncio and C. Herley, “Where Do Security Policies Come From?,” *Proc. 6th Symp. Usable Privacy and Security*, ACM, 2010, article 10.
10. D. Florêncio and C. Herley, “Sex, Lies and Cyber-Crime Surveys,” *Proc. Workshop Economics of Information Security and Privacy*, Springer, 2011, pp. 35–53.
11. R. Anderson and T. Moore, “The Economics of Information Security,” *Science*, vol. 314, no. 5799, 2006, pp. 610–613.
12. D. Florêncio and C. Herley, “Is Everything We Know about Password-Stealing Wrong?,” *IEEE Security & Privacy*, vol. 10, no. 6, 2012, pp. 63–69.
13. G.D. Crescenzo, R.J. Lipton, and S. Walfish, “Perfectly Secure Password Protocols in the Bounded Retrieval Model,” *Proc. 3rd Theory of Cryptography Conference*, Springer, 2006, pp. 225–244.
14. T.S. Teo and W.R. King, “Integration between Business Planning and Information Systems Planning: An Evolutionary-Contingency Perspective,” *J. Management Information Systems*, vol. 14, no. 1, 1997, pp. 185–214.
15. I. Kirlappos, A. Beaument, and M.A. Sasse, “‘Comply or Die’ Is Dead: Long Live Security-Aware Principal Agents,” *Financial Cryptography and Data Security*, LNCS 7862, Springer, 2013, pp. 70–82.

Cormac Herley is a principal researcher at Microsoft Research. His current interests include security, usability, economics, and data analysis. Herley received a PhD from Columbia University. Contact him at cormac@microsoft.com.



SecureComm
 10th International Conference on
 Security and Privacy in Communication Networks
 September 24–26, 2014 Beijing, China

- Main Conference
 Important Dates :
 Submission Deadline: April 21, 2014 Notification of Acceptance: June 30, 2014
- Industry Track
- Workshops
 Android Security, Secure Cloud Computing,
 Home Automation Security, etc.
- Poster Sessions
- Doctoral Symposium

<http://securecomm.org/2014>



 中国科学院 信息工程研究所
 INSTITUTE OF INFORMATION ENGINEERING, CAS


 EAI European Alliance for Innovation
 Empowering the Innovation Community


 IIS